

Security Incident Response Plan

<APPLICATION / SYSTEM NAME AS IT APPEARS IN SOCREG>

<DATE>

Table of Contents

[Introduction](#)

[System Overview](#)

[Architecture Model](#)

[Incident Response Procedures](#)

[Security Incident confirmation](#)

[Assess Initial Impact](#)

[Escalate to ISO](#)

[Support P3/P4 Data System Incident Response Activities](#)

[Remediation for P1 Systems](#)

[Appendix A - PCI Procedures](#)

[Appendix B - Reporting Requirements for Credit Card Companies](#)

I. Introduction

This is the Security Incident Response Plan for <APPLICATION/SYSTEM NAME> that documents the procedures for responding to a security incident.

The goal of the Security Incident Response Plan is to provide tools to help technical staff who are responsible for supporting systems that are required to comply with the campus [Minimum Security Standard for Electronic Equipment](#) (MSSEI) policy to effectively respond to security incidents, and to minimize any negative impact to institutional operations through a set of detection, analysis and recovery activities.

II. System Overview

<Provide a summary of the covered system's business and technical functions. If the information is maintained in other documents, provide links to those documents. Include the name of the application/system as it is registered in [Socreg](#)>

A. Architecture Model

<Attach a high-level diagram of the application/system data flow and data storage, including all interconnected system names and networks (e.g., public vs. private)>

B. System Hardware Inventory

<Insert hardware inventory of covered devices as required by [MSSEI 1.3 Covered system inventory](#), e.g., provide a link to the inventory file>

C. Audit Logging

<Insert details of the application system audit logging processes as required by [MSSEI 12 Security Audit Logging](#). Include details about where the log files are located, as well as a brief description of the events captured in each log file>

Definitions

Breach - A breach is defined as a security incident that requires notification to affected individuals, where the protected data of the affected individual was, or is reasonably believed to have been, accessed by an unauthorized person.

Event - An event is any observable occurrence on a system or network, e.g. system login, file creation or application transaction.

Security Incident - An event, or series of events, that violates, or is about to violate, campus policies and standards.

P3/P4 Data - P3/P4 Data is Protection Level 3 (P3) and Protection Level 4 (P4) data that is classified by the [Campus Data Classification Standard](#) as moderate or highly sensitive due to the potential for negative impact to campus if such data is inappropriately accessed.

III. System Contacts

The <APPLICATION/SYSTEM NAME> Incident Response Team includes the following staff:

Incident Handler:	
Email Address:	
Phone Number:	

Service Manager:	
Email Address:	

Phone Number:	
---------------	--

The **Incident Handler** is a security contact who has technical knowledge of the application/system and full understanding of the Security Incident Response Plan.

All suspicious events reported by end users of the application/system should be directed to the *Incident Handler*. There must be clear and easily accessible documentation for end users of the application/system to contact the *Incident Handler* to report any suspicious events.

The [Service Manager](#) is an authority/decision maker for the application/system who understands the business impact of the system and its unavailability. The [Resource Proprietor](#) should take on the responsibilities of the Resource Manager or designate a qualified staff member for this role.

IV. Incident Response Procedures

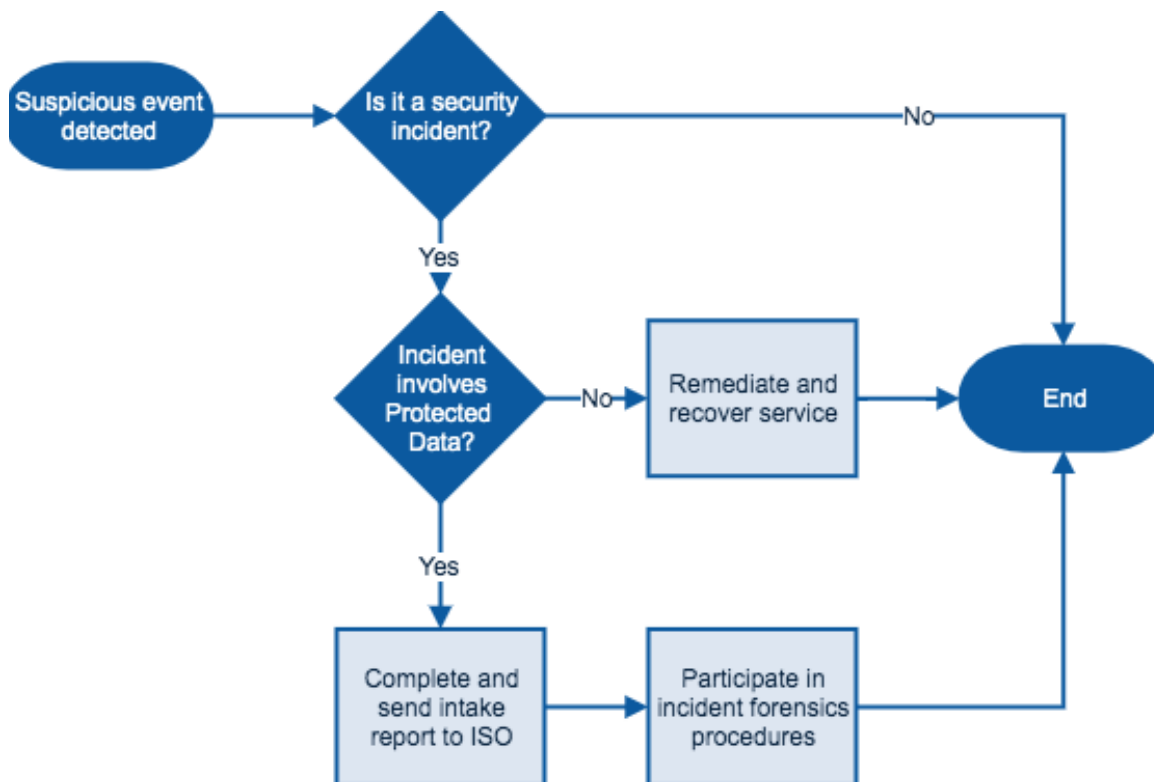


Fig 1. High Level Incident Response Workflow

The high level incident response steps can be summarized in the flowchart above. The sections below outline detailed procedures for each step.

Step 1: Security Incident Confirmation

Once a suspicious event is detected, the *Incident Handler* should start by determining whether suspicious system events constitute a *Security Incident*.

- Ask the end users to describe the sequence of events, including how they became suspicious and the actions they have taken so far
- List the devices that are affected, their functions, and the number of users that might be impacted
- Review the evidence of compromise (email samples, screenshots, suspicious files, etc.)
- Document any observations and decisions made based upon discussion or evidence analysis

The rationale used to determine whether the suspicious events constitute a *Security Incident* must be documented.

If the suspicious events are confirmed to be a Security Incident, continue to the next step to **Assess Initial Impact**.

If the suspicious events are one-time computer glitches or user misjudgement, and does not fit the definition of a *Security Incident*, document the decision and close the incident response process.

In cases where the detected event(s) is contributing to system disruption, but is not a result of malicious activities, the incident should be reported to the appropriate IT support personnel. Events involving campus wide enterprise application outages, network outages, and system malfunctions should be reported to [IT Client Services](#) (ITCS).

Additional information on reporting different types of non-security related incidents can be found on the [security website](#).

Step 2: Assess Initial Impact

Determine whether data classified as [Protection Level 3, or 4](#) (*P3/P4 Data*) may be involved in the security incident by looking for clues about what type of data can be accessed from affected systems and/or credentials.

The following are a sample set of questions to help guide the analysis:

- Do affected systems store *P3/P4 Data* locally?
- Do affected systems have access to network file shares storing *P3/P4 Data*?

- Are affected systems being used by users/credentials that have access to *P3/P4 Data*?
- Do affected systems have programmatic access to *P3/P4 Data* stored remotely?
- Are affected systems used to access applications storing/processing *P3/P4 Data*?

If the affected system does have direct or indirect access to *P3/P4 Data*, follow the procedures in the next step to **Escalate to ISO (Information Security Office)** by completing and emailing an intake report, described below. [Additional incident reporting details](#).

If there is no *P3/P4 Data* is involved, skip to [Step 5: Remediation for P1 Systems](#).

Step 3: Escalate to ISO

For security incident involving *P3/P4 Data*, the incident should be **escalated to ISO immediately** by emailing urgent@security.berkeley.edu with the following "Intake report" information:

- Contact person's name and phone number
- IP address, hostname and physical location of Socreg)
- What types of covered data was available on/from the breached host?
 - Full name
 - Social security number
 - Driver's license number or California identification card number
 - Credit or financial account number card number (including PIN or expiration date)
 - Bank account number (including PIN or other access information)
 - Medical information or health insurance information
 - Other
- For each file containing personal information specify:
 - Name of the file
 - Size of the file
 - Location of (full path to) the file
- Was the data encrypted? If so, how?
- Describe the impact of the incident (e.g. the number of data records are compromised or the number of users that are affected by unavailable system)
- Describe the security incident, including a timeline of activities, how the incident was detected, impact (business and technical) of the incident, details of mitigating controls in place such as what data encryption mechanism was used
- Describe action being taken on the breached system (what's the state of the system now, etc)

Important: After a security incident is reported to ISO, do not disconnect or logon to the breached system until instructed by the ISO Security Analyst.

Step 4: Support P3/P4 Data Incident Response Activities

Once a *Security Incident* is reported to ISO, a Security Analyst will be immediately assigned to lead the remaining incident response activities going forward.

Before taking steps to remove malicious elements and recover affected systems to a normal operational state, the ISO Security Analyst will work to obtain evidence needed to determine whether *P3/P4 data* was inappropriately accessed. The level of evidence may differ depending on the applicable laws or regulations, but in all cases, the *Incident Handler* will be asked to support any evidence gathering or remediation activities.

Step 5: Remediation for P1 Systems

If the security incident is determined not to involve *P3/P4 data*, the *Incident Handler* should proceed with the following steps to return affected systems to a normal operational state:

- Change passwords of affected users using a non-affected computer; priority should be given to CalNet and other passwords that allow access to institutional systems
- If necessary to limit the spread of malware or data leakage, ask the end user to disconnect the affected system from network (e.g., unplug the ethernet cable and/or turn off Wifi connection)
- If available, collect any operating system or application level audit logs to capture events that show what data was accessed, when the suspicious event started/stopped, and what action was performed
- Repair affected system

Examples of compromises and the corresponding remediation procedures are provided below. Note that depending on the nature of compromise, a combination of remediation procedures may be needed to fully address the cause:

Compromise scenario	Remediation Procedures
Malware	• For systems compromised by malware, the <i>Incident Handler</i> should consider rebuilding the system from scratch; detailed procedures for rebuilding a system are provided on the campus security website • For compromised systems where rebuilding is not an option, the <i>Incident Handler</i> can follow procedures to remove malware
Data theft	• Remove inappropriate access privileges from rogue or

	malicious user account
Network intrusion attempt	• Update firewall configuration to restrict network access to exposed services and/or ports

Critical additional steps:

- In any compromise scenario, change the password of affected user accounts
- If appropriate, after clean-up activities restore data from back-up
- Patch and configure system based on campus standards (MSSND & MSSEI)
- Thoroughly document actions performed and observations made during the incident response process